CCC Attestation SIG · 20 October 2026

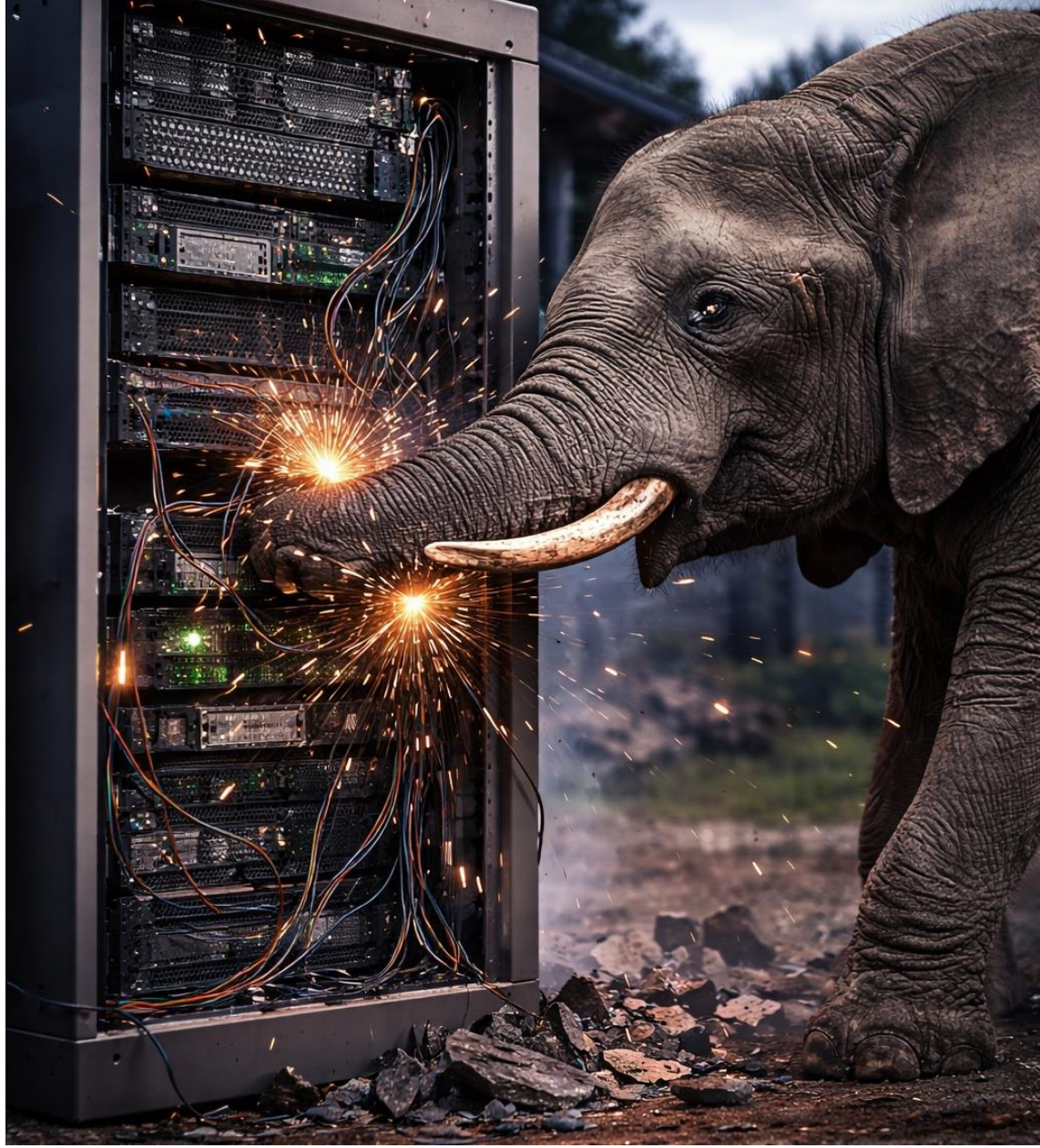
A CoRIM Profile for Intel Platform Ownership Endorsements (POE)

draft-bzb-rats-intel-poe-endorsements-02

Mateusz Bronk, Intel

Physical Attacks on Intel® SGX/TDX – the Elephant in the Room

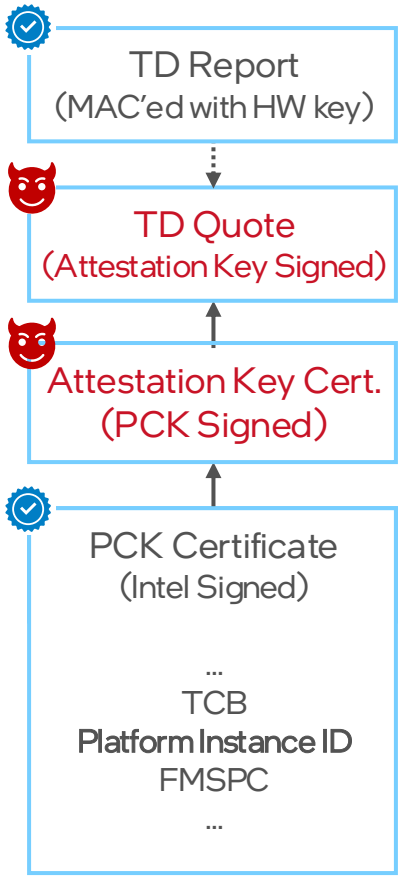
- Physical access changes the threat model
  - Memory probing & bus observation
  - Fault injection
  - Cold-boot
  - Ciphertext observation & tampering
- Customers
  - Might trust CSP to not launch physical attacks
  - Currently do not have a way to verify physical ownership of a platform
- Goal of Platform Ownership Endorsements (POE): Link attestation evidence to a trusted physical owner



Slide source: Intel POE flow presentation @ CCC Attestation SIG, June 16 (slide 2)

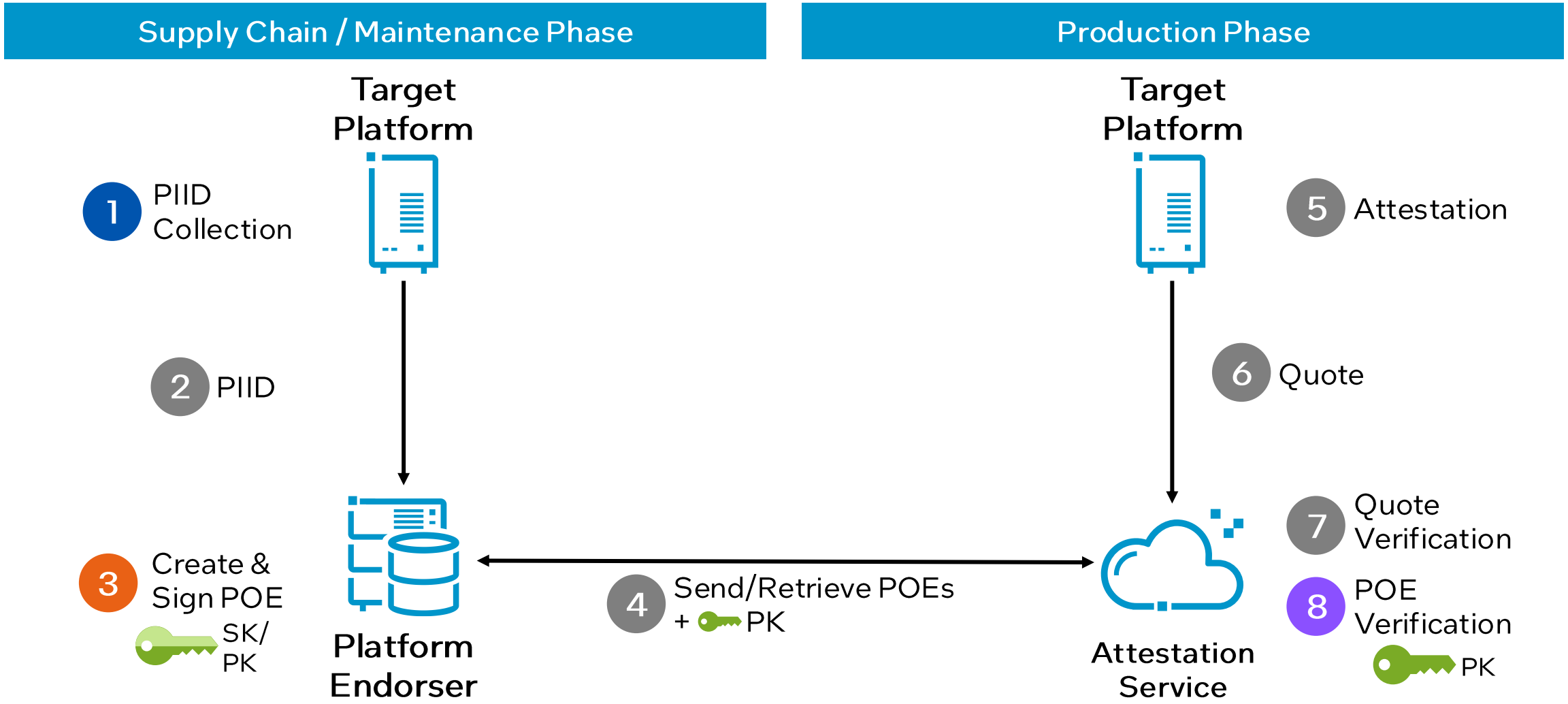
Hardening Remote Attestation

- Relying Party must
  - be able to recognize the physical owner of the machine
  - trust physical owner to prevent physical attacks
- Key insights for solution:
  - Attacker cannot modify PCK Certificate
  - PCK Certificate contains unique Platform Instance ID (PIID)
    - PIID is generated randomly on first boot
    - PIID survives reboots
    - PIID can be reset by explicitly performing an "Intel SGX Factory Reset"
    - PIID is contained in the Platform Manifest, PCK Certs, and TD quotes



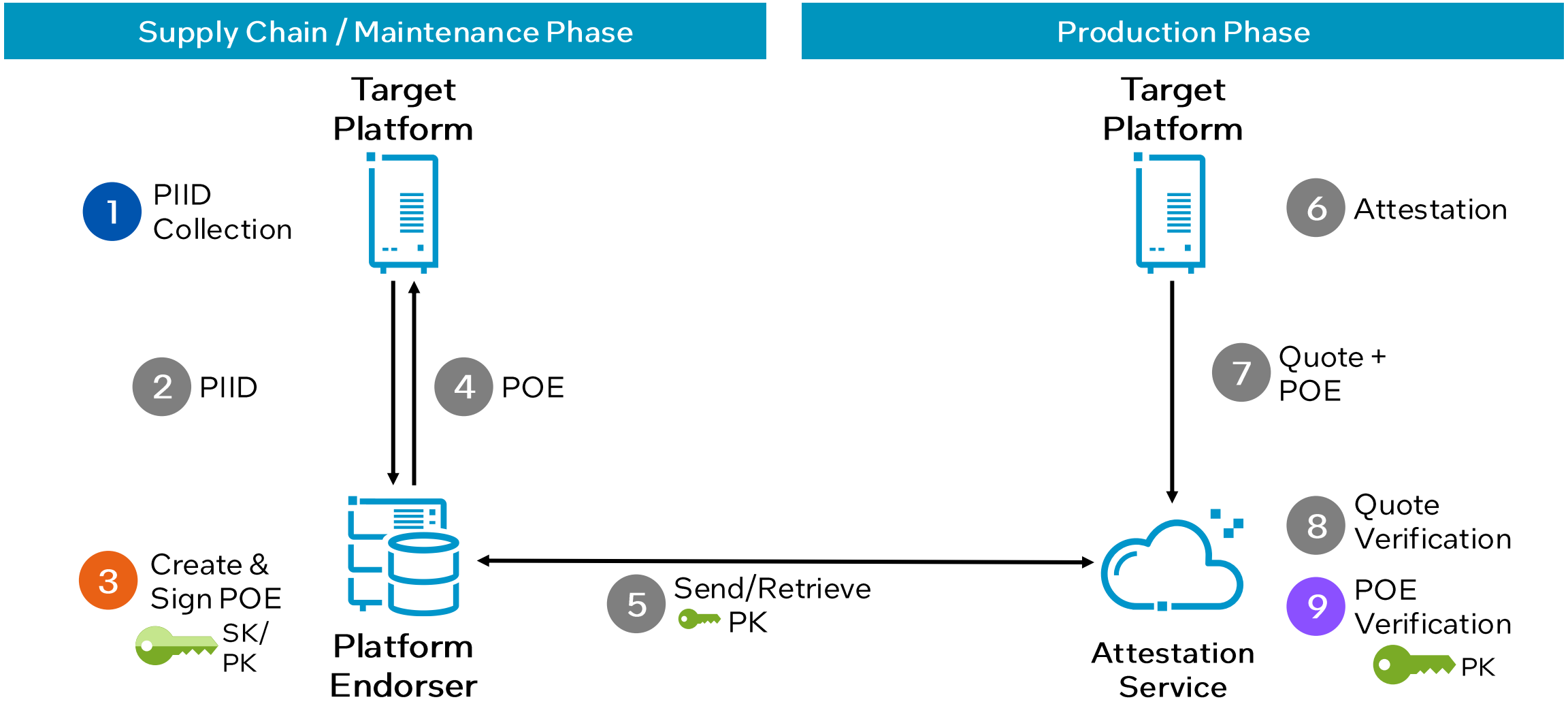
Slide source: Intel POE flow presentation @ CCC Attestation SIG, June 16 (slide 6)

POE Flow – Short Term



Slide source: Intel POE flow presentation @ CCC Attestation SIG, June 16 (slide 8)

POE Flow – Longer Term



Slide source: Intel POE flow presentation @ CCC Attestation SIG, June 16 (slide 9)

Profile at a glance

- Signed CoRIM (COSE_Sign1)
  → **exactly 1 CoMID**
  → **exactly 1 conditional-endorsement-triple**

- **Condition:** "the attested platform presents PIID = X"
- **Endorsement:** "its owner is `csp.example`"

- Profile `tag:intel.com,2026:tee.poe#1.0`
- Signed by the **owner / CSP / fleet manager / CA**, not by Intel
  - Separate from the Intel-signed TCB profile (draft-cds-rats-intel-corim-profile)
- One binding per CoRIM: own tag-id, validity, lifecycle

```
/ corim-map / {
  / id           / 0 : h'…',       ; UUIDv8
  / tags         / 1 : [           ; exactly 1
      506(<< concise-mid-tag >>) ],
  / profile      / 3 :
      32("tag:intel.com,2026:tee.poe#1.0"),
  / rim-validity / 4 : { … }       ; REQUIRED
}

/ concise-mid-tag / {
  / tag-identity / 1 : { / tag-id / 0 : h'…' },
  / triples      / 4 : {
    / conditional-endorsement-triples / 10 : [     ; exactly 1
      [ / conditions   / [ … PIID = X … ],
        / endorsements / [ … owner = "csp.example" … ]
      ]
    ]
  }
}
```

Conditions clause: "PIID = X"

```
/ stateful-environment-record / [
  / environment-map / {
    / class / 0 : {
      / class-id / 0 :
        111(h'6086480186F84D010D020601')
        ; 2.16.840.1.113741.1.13.2.6.1
        ; Intel PIID environment
    }
  },
  / claims-list / [
    / measurement-map / {
      / mkey / 0 : "tee.poe.platform-binding",  ; optional
      / mval / 1 : {
        / tee.platform-instance-id /
        -101 : h'…'       ; PIID, bstr (16B|32B)
      } } ] ]
```

Draft-02 §4.3, Figure 2

- `class-id`: Intel PIID environment OID. The PIID value comes from the PCK cert (ext. 1.2.840.113741.1.13.1.6)
- `-101 tee.platform-instance-id`: bstr
  - Compared verbatim over the full length; a length mismatch is a non-match
  - Shared with the Intel profile (tee.* namespace)
- `mkey` is mostly diagnostic aid; appraisal doesn't depend on it
- **MUST NOT:** class vendor/model; `authorized-by` (authority comes from the COSE x5chain)

Endorsements clause: "owner = csp.example"

```
/ endorsed-triple-record / [
  / environment-map / {
    / class / 0 : {
      / class-id / 0 :
        111(h'6086480186F84D010D020C01')
        ; 2.16.840.1.113741.1.13.2.12.1
        ; Intel Owner-Endorsement env (v1)
    }
  },
  / measurements / [
    / measurement-map / {
      / mkey / 0 : "tee.poe.ownership-claims",    ; optional
      / mval / 1 : {
        / tee.owner-name / -401 : "csp.example"
      } } ] ]
```

Draft-02 §4.4, §7.2, Figure 3

- `-401` `tee.owner-name`: tstr of 1–1024 B, exactly one entry
- SHOULD be a **DNS name the owner controls**
  - MAY: URI, LEI, DUNS, X.500 DN; local/free-form strings SHOULD NOT be used
- The Verifier **surfaces** owner-name **and** issuer (authority) - x5chain leaf, CWT `iss`
- The verifier's appraisal outcome **does not depend** on owner-name. That is the RP's policy
- **Owner** = **physical custody**, not legal title. How custody is established is Issuer (Endorser) policy
- **Issuer ≠ Owner** is allowed: a delegated service, or several issuers (e.g. an auditor) for one binding

Design choice: PIID is a predicate, not an instance

Conditional ownership endorsement (Intel POE)

conditional-endorsement: **ownership, conditioned on the instance**

```
[ / conditions / [ [
    { / class / 0 : { 0 : 111(PIID-env OID) } },
    [ { 1 : { -101 : PIID } } ] ] ],  ; predicate
  / endorsements / [ [
    { / class / 0 : { 0 : 111(Owner OID) } },
    [ { 1 : { -401 : "csp.example" } } ] ] ] ]
```

Instance-bound key endorsement (e.g. Arm CCA)

attest-key-triple: the endorsement is **about the instance**

```
[ / environment / {
    / class / 0 : { / class-id / 0 : 560(impl-id) },
    / instance / 1 : 550(UEID) },     ; subject
  [ CPAK public key ] ]
```

Why:

1. **Follows the Intel profile:** TDX/SGX evidence reports the PIID as a **measured value** (`-101`); the POE matches that same shape.
2. **PIID is an epoch, not the hardware:** regenerated on SGX Factory Reset / Platform Establishment, so it behaves like reported state.
3. **Trust-domain hygiene:** the owner doesn't describe Intel's platform; it observes Intel's PIID and asserts in its **own** environment, under its own key.
4. **Extensibility:** the conditional claim can carry further conditions (e.g. *"if PIID = X, TCB level is >= Y, and has GPU device D attached"*) in future major versions (if required)

Lifecycle & validity

- **No in-band revocation of individual POEs.**
  - x509 revocation for keys; validity windows for content
    - `rim-validity` is **required**;
      the Verifier intersects it with the x5chain validity, and an empty intersection means reject
    - Keys: CRL / OCSP on the issuer chain.
      Scope with your CA layout (an intermediate CA cert. per fleet / tenant / batch)
- **Refresh**: before expiry
  - at convenient cadence e.g. platform servicing/TCB updates…: new PCK cert, same PIID)
  - Intel generator's default lifetime is 5Y (pilot-friendly). No early per-POE revocation, so **production: short windows + reset on decommission**
  - Optional `tee.refresh-uri` (protected header): where to fetch a fresh POE.
    A hint, **not** `dependent-rims`

- **Ownership change** → new POE (new tag-id) + **SGX Factory Reset** → new PIID → every old POE is orphaned
- **Privacy:** a POE discloses the PIID ↔ owner link to its recipients; a **factory reset unlinks**

Status & tooling

- **Whitepaper:** intel.com/content/www/us/en/developer/articles/technical/software-security-guidance/technical-documentation/platform-ownership-endorsements.html

- **Profile: Draft:** -00 (Jul 20) → -01 (Jul 23) → -02 (Sep 28) · Informational
  - Datatracker: datatracker.ietf.org/doc/draft-bzb-rats-intel-poe-endorsements
  - Source & issues: github.com/mbronk-intc/draft-bzb-rats-intel-poe-endorsements
  - Released producer CDDL + instance-conformance test harness

- **Tools (BSD-3):** github.com/intel/confidential-computing.tee.dcap.poe
  - **poe-gen-tool**: extracts the PIID (Platform Manifest / PCK cert / quote), builds and signs the POE CoRIM
  - **poe-eval-tool**: parses the POE, matches the PIID against evidence, surfaces owner + issuer
  - Both track `tee.poe#1.0`

- **Next:** DCAP integration (longer-term flow);

Beyond Intel?

Intel-specific

- PIID semantics & lifetime
- How the Verifier extracts the PIID (PCK cert / quote)

Profile-defined encoding extensions:

- Two OIDs: PIID class, owner class
- `-401` for owner name (a `tstr`), `-101` for PIID
- "`tee.refresh-url`" hint

Reusable pattern

- **Conditional endorsement:** "evidence presents instance-ID X" → "owner = <DNS name>"
- Signed by the **owner**; no silicon vendor in the loop
- Another TEE can plug in its own instance-ID class & key
- Generic names chosen with this in mind: `tee.owner-name`, `tee.refresh-uri`

What's next:

1. **Alignment:**
   Does the SIG see it beneficial to converge around a single profile? Is this a good base? Any extensions to base CoRIM?

2. **Beyond ownership:**
   Today's POE profile is built around a single claim (physical custody).
   Is more flexibility needed for issuers to add their own platform attributes (i.e. location)?


intel